280--Lab - Malware de firewall

En esta práctica se muestra como crear un grupo de reglas de firewall, actualizar un firewall de red de AWS y verificar que el acceso a los sitios maliciosos esté bloqueado.

Escenario

Se requiere reforzar la seguridad de la red debido a que los usuarios han descargado software malicioso accidentalmente después de acceder a sitios web específicos.

Confirmar la accesibilidad

Una instancia EC2 se ha aprovisionado para la realización de pruebas.

Nos conectamos a la instancia mediante AWS Systems Manager Session Manager

Comprobamos que estamos en el directorio personal

```
sh-4.2$ cd ~
sh-4.2$ pwd
/home/ssm-user
```

Wget es un comando utilizado para descargar archivos desde servidores web a través de protocolos como HTTP, HTTPS y FTP.

Con *wget* verificamos la descarga de los archivos maliciosos de los sitios web identificados

```
sh-4.2$ wget http://malware.wicar.org/data/js_crypto_miner.html
--2026-01-12 23:02:29--  http://malware.wicar.org/data/js_crypto_miner.html
Resolving malware.wicar.org (malware.wicar.org)... 208.94.116.246, 2607:ff18:80:6::6a08
Connecting to malware.wicar.org (malware.wicar.org)|208.94.116.246|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 366 [text/html]
Saving to: 'js_crypto_miner.html'

100%[===================================================================================

2026-01-12 23:02:30 (52.0 MB/s) - 'js_crypto_miner.html' saved [366/366]
```

```
sh-4.2$ wget http://malware.wicar.org/data/java_jre17_exec.html
--2026-01-12 23:03:28--  http://malware.wicar.org/data/java_jre17_exec.html
Resolving malware.wicar.org (malware.wicar.org)... 208.94.116.246, 2607:ff18:80:6::6a08
Connecting to malware.wicar.org (malware.wicar.org)|208.94.116.246|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 129 [text/html]
Saving to: 'java_jre17_exec.html'

100%[===================================================================================================

2026-01-12 23:03:29 (19.6 MB/s) - 'java_jre17_exec.html' saved [129/129]
```

Con *ls* comprobamos que los archivos han sido descargados

```
sh-4.2$ ls
java_jre17_exec.html  js_crypto_miner.html
```

Inspeccionar el firewall de red

La función principal de un firewall es actuar como una barrera entre una red interna de confianza y redes externas no confiables, como Internet.

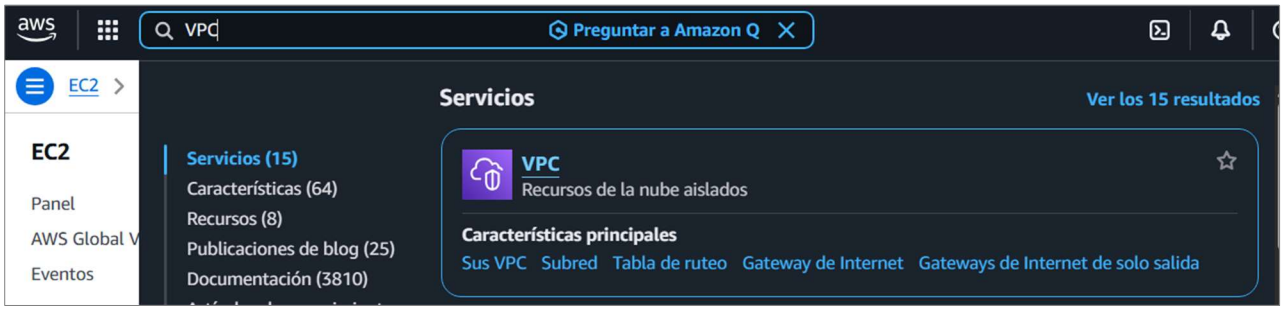
Un grupo de reglas de firewall es un contenedor que agrupa un conjunto de instrucciones de seguridad (reglas) para que el firewall sepa qué hacer con el tráfico de red.

Los grupos de regla pueden ser sin estado y con estado.

Las diferencias entre ambos son las siguientes:

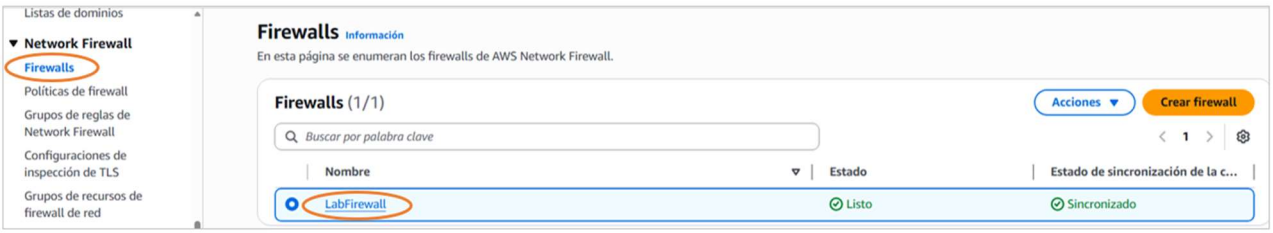
Característica	Sin Estado (Stateless)	Con Estado (Stateful)
Memoria	No recuerda paquetes anteriores.	Recuerda el contexto de la conexión.
Velocidad	Muy rápido (analiza menos datos).	Un poco más lento (debe consultar su tabla).
Seguridad	Básica (fácil de engañar).	Alta (difícil de engañar con paquetes falsos).
Reglas	Necesitas reglas para tráfico de entrada Y salida.	Solo necesitas reglas para iniciar la conexión.

Para inspeccionar el firewall de red que tiene la VPC, nos dirigimos al panel de VPC



En *Network Firewall* accedemos a *Firewalls*

Seleccionamos el firewall "LabFirewall"



El firewall tiene una política de firewall asociada: *LabFirewallPolicy*

Seleccionamos la política

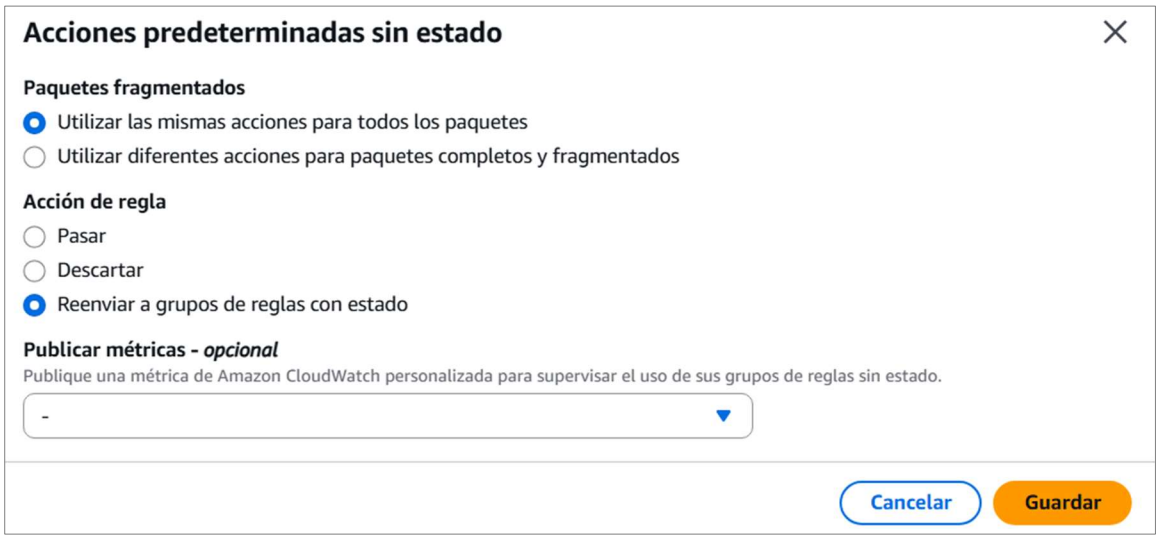
Podemos ver las acciones predeterminadas sin estado de la política

- Acción para paquetes completos ("Pasar"): Significa que si un paquete de datos llega completo y no coincide con ninguna regla de bloqueo específica, el firewall lo dejará entrar a la red.

- Acción para paquetes fragmentados ("Descartar"): Los paquetes fragmentados a veces se usan en ataques para evadir seguridad. Aquí, el firewall está configurado para eliminarlos automáticamente por seguridad.

Hacemos clic en *Editar* para modificar la política

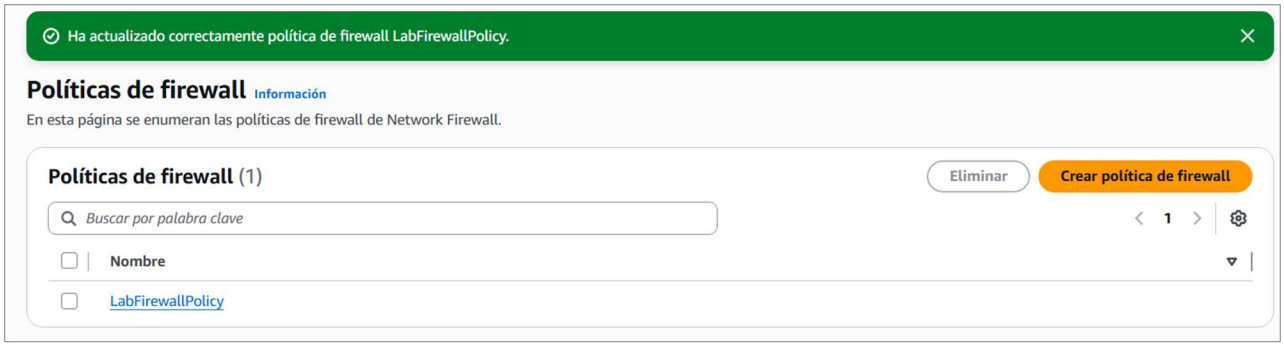
Indicamos la siguiente configuración y hacemos clic en *Guardar*



Esta configuración sirve para definir qué debe hacer el sistema con el tráfico de red cuando este no coincide con ninguna de las reglas manuales que se han creado.

Hemos indicado que se apliquen las mismas reglas tanto para paquetes completos como fragmentados.

En *Acción de regla* hemos indicado que se haga una inspección profunda (con estado). Al elegir "Reenviar a grupos de reglas con estado", le estamos indicando al firewall: "Si este paquete no rompe ninguna regla básica, no lo dejes pasar todavía; mándalo al motor 'con estado' para que lo analice más a fondo".



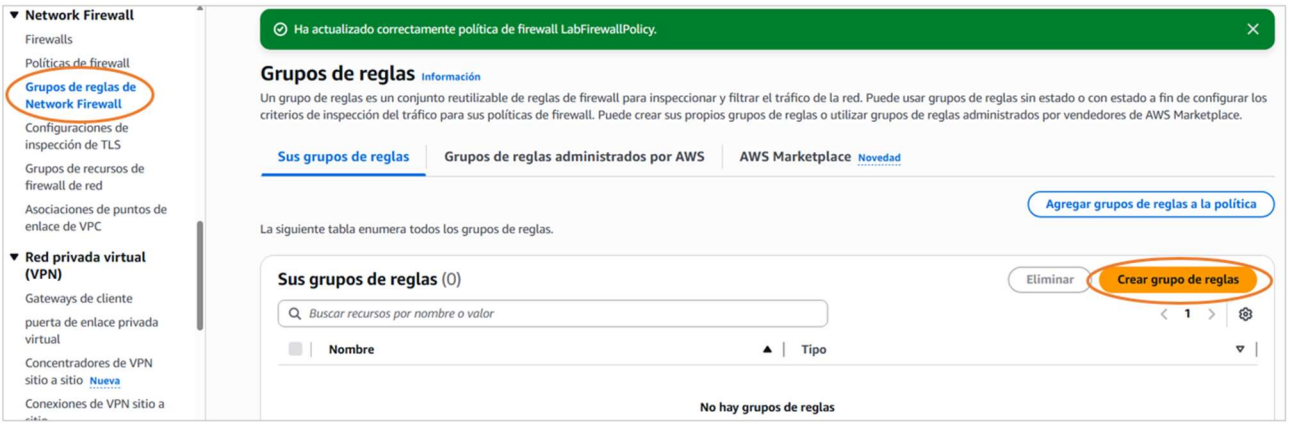
La política de firewall se ha actualizado.

Crear grupo de regla de firewall

Ahora crearemos el grupo de regla que asignaremos a la política vista anteriormente.

En *Network Firewall* hacemos clic en *Grupos de reglas de Network Firewall*

Hacemos clic en *Crear grupo de reglas*



Indicamos la siguiente configuración.

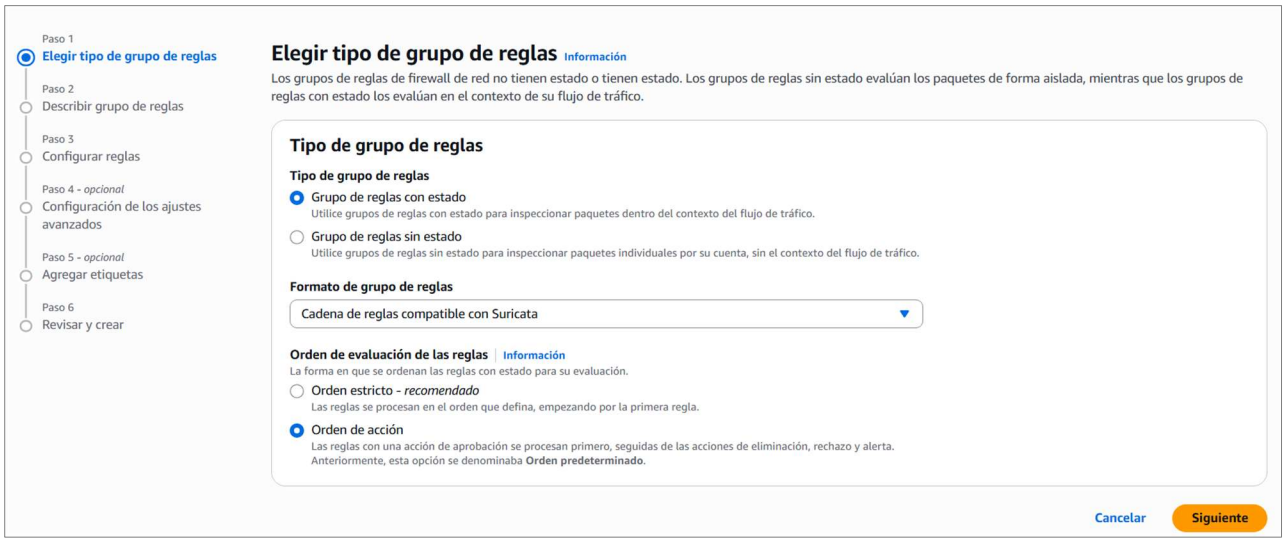
Especificamos que el orden de evaluación de las reglas es *Orden de acción*. Esto significa que el firewall procesará las reglas en un orden lógico de seguridad:

1. Primero las reglas de aprobación
2. Luego las de eliminación y rechazo
3. Finalmente las de alerta

La cadena de reglas compatible con Suricata es un formato estándar de la industria utilizado para escribir reglas de detección y prevención de intrusiones. En el contexto de AWS Network Firewall, permite crear reglas personalizadas mucho más potentes que las simples listas de IP.

Suricata es un motor de seguridad de código abierto de alto rendimiento que actúa como IDS e IPS. AWS utiliza este motor internamente para procesar las reglas "con estado".

Hacemos clic en *Siguiente*

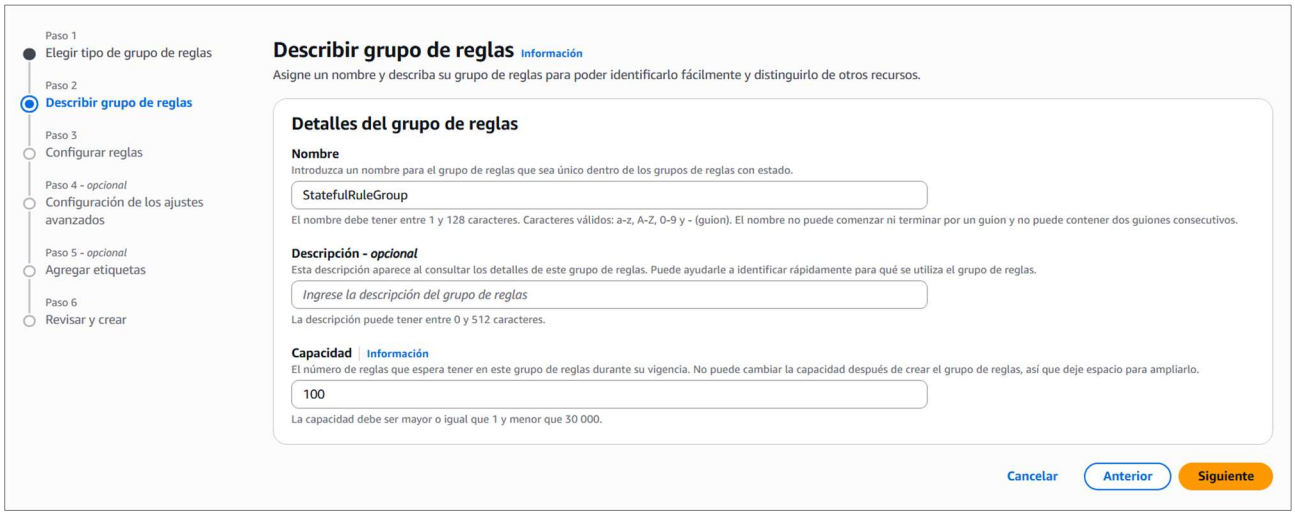


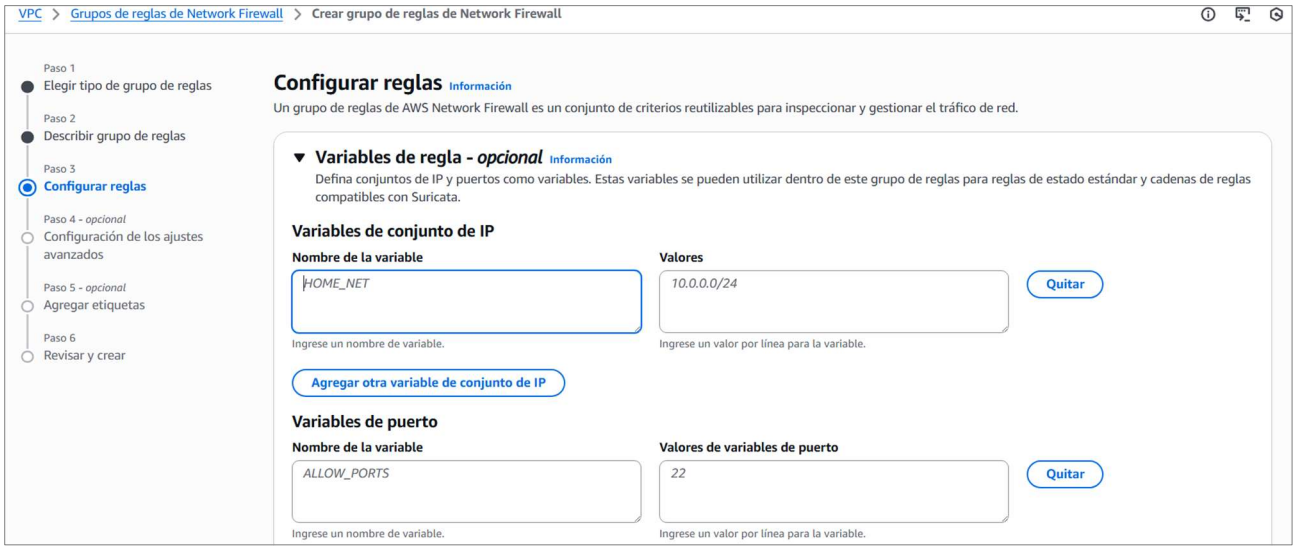
Especificamos la capacidad en 100.

La capacidad es un valor numérico que se debe asignar a cada grupo de reglas al momento de crearlo. AWS utiliza este número para reservar la cantidad de memoria y recursos de procesamiento necesarios para ejecutar las reglas.

La capacidad es un valor fijo, una vez que se crea el grupo de reglas, no se puede cambiar su capacidad.

Hacemos clic en *Siguiente*





Especificamos las reglas compatibles con Suricata:

```
drop http $HOME_NET any -> $EXTERNAL_NET 80 (msg:"MALWARE custom solution"; flow:
to_server,established; classtype:trojan-activity; sid:2002001;
content:"/data/js_crypto_miner.html";http_uri; rev:1;)

drop http $HOME_NET any -> $EXTERNAL_NET 80 (msg:"MALWARE custom solution"; flow:
to_server,established; classtype:trojan-activity; sid:2002002;
content:"/data/java_jre17_exec.html";http_uri; rev:1;)
```

Con *drop* el firewall no solo detecta el tráfico, sino que elimina los paquetes y corta la conexión inmediatamente.

http le dice al motor que debe realizar una inspección profunda del protocolo web, no solo mirar puertos.

$HOME_NET any -> $EXTERNAL_NET 80 bloquea el tráfico que sale desde cualquier puerto de la red interna hacia el puerto 80 (HTTP estándar) de Internet.

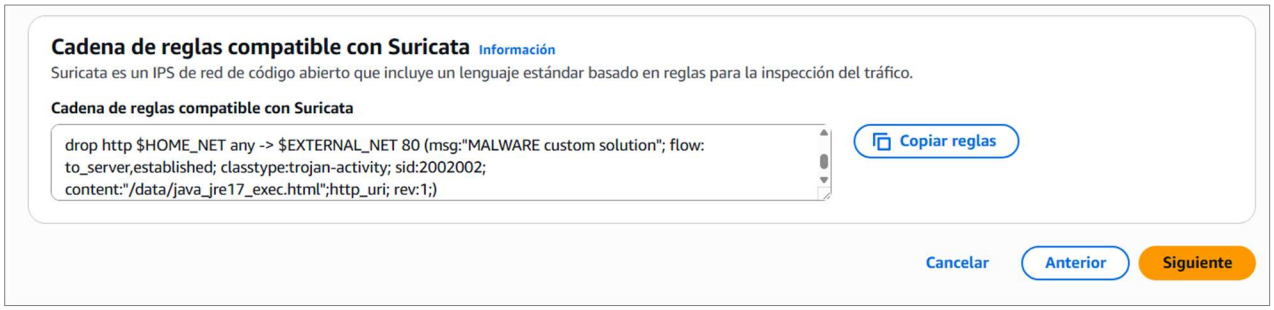
msg:"MALWARE custom solution" es el nombre que aparecerá en los logs cuando la regla se active.

flow:to_server,established indica que la regla solo se activa si la conexión ya se estableció con éxito hacia un servidor externo, evitando falsos positivos.

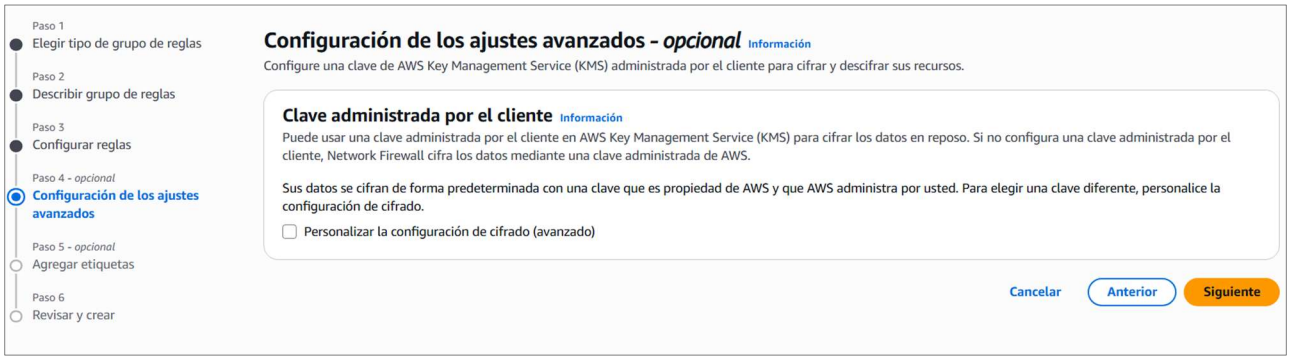
classtype:trojan-activity categoriza la alerta como una actividad de troyano en los informes de seguridad.

sid:2002001; rev:1 es el identificador único de la regla.

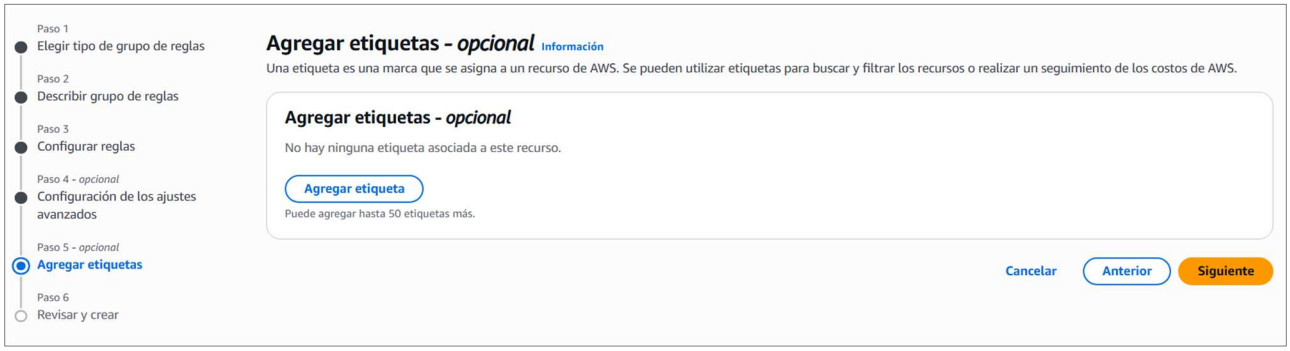
content:"/data/js_crypto_miner.html"; http_uri es la cadena de texto que el firewall buscará dentro de la dirección URL que el usuario intenta visitar.



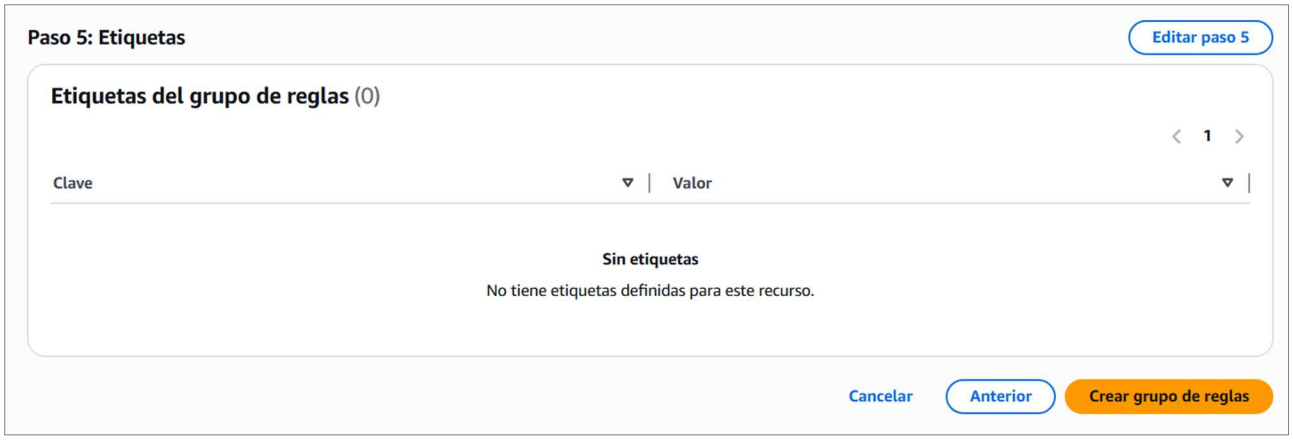
Hacemos clic en *Siguiente*



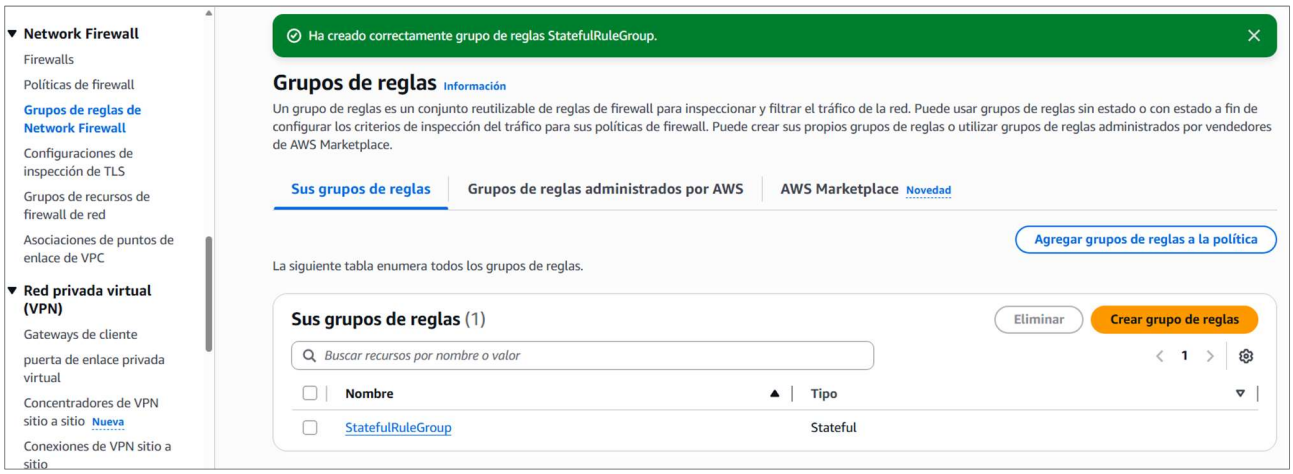
Hacemos clic en *Siguiente*



Hacemos clic en *Crear grupo de reglas*



Se ha creado el grupo de reglas

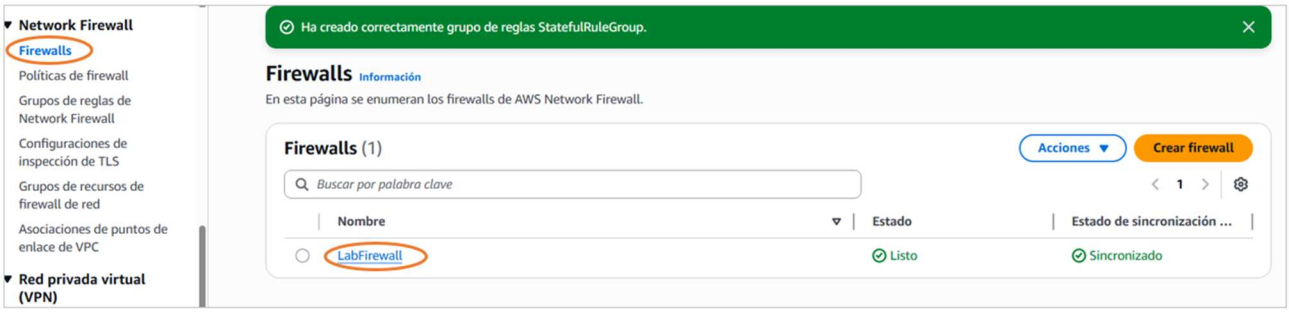


Asociar el grupo de reglas al firewall de red

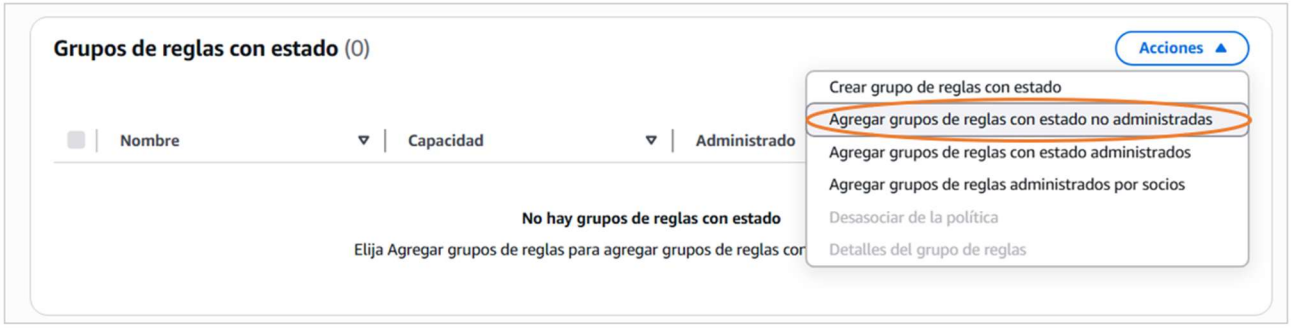
Ahora asociaremos el grupo de reglas creado al firewall de red.

Para esto nos dirigimos a *Network Firewall -> Firewalls*

Seleccionamos el firewall *LabFirewall*

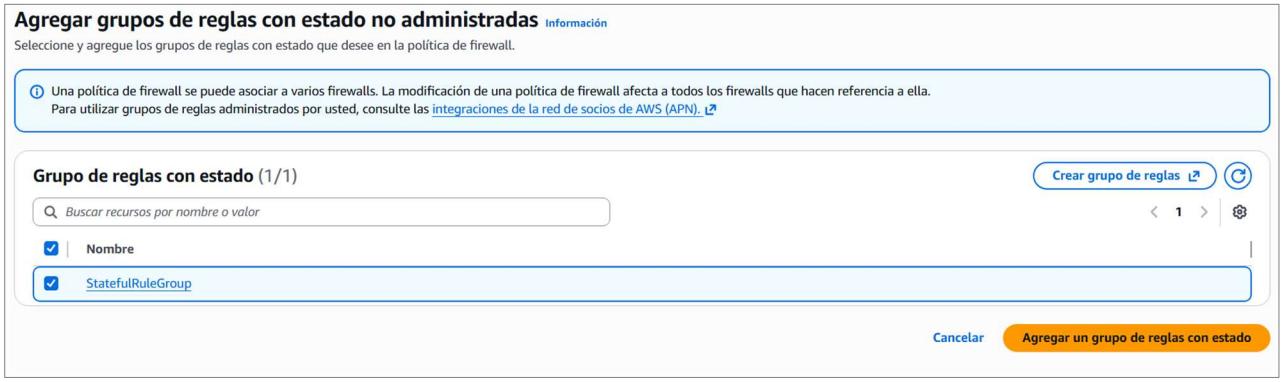


Seleccionamos *Acciones -> Agregar grupos de reglas con estado no administradas*

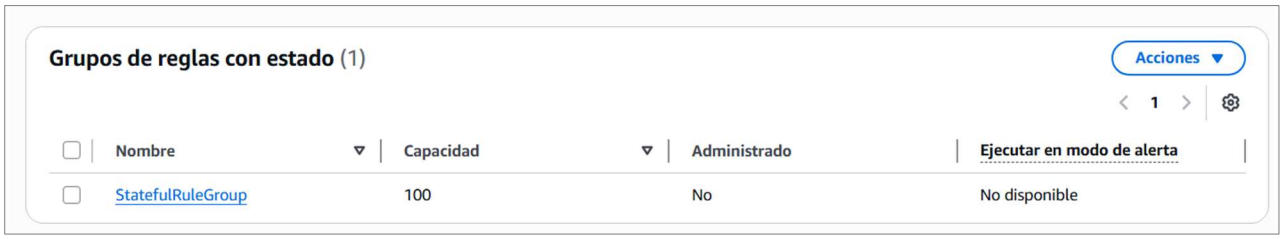


En AWS Network Firewall, un grupo de reglas se considera no administrado cuando el cliente es el responsable de crear, definir y mantener el contenido de sus reglas. El cliente define la lógica y la capacidad.

Seleccionamos el grupo de reglas *StatefulRuleGroup* y hacemos clic en *Agregar un grupo de reglas con estado*



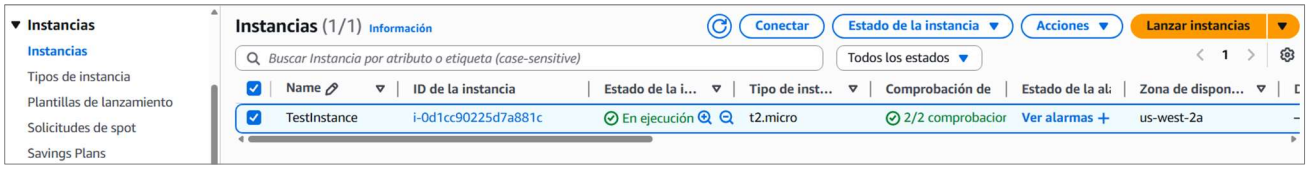
El grupo de reglas se ha agregado a la política



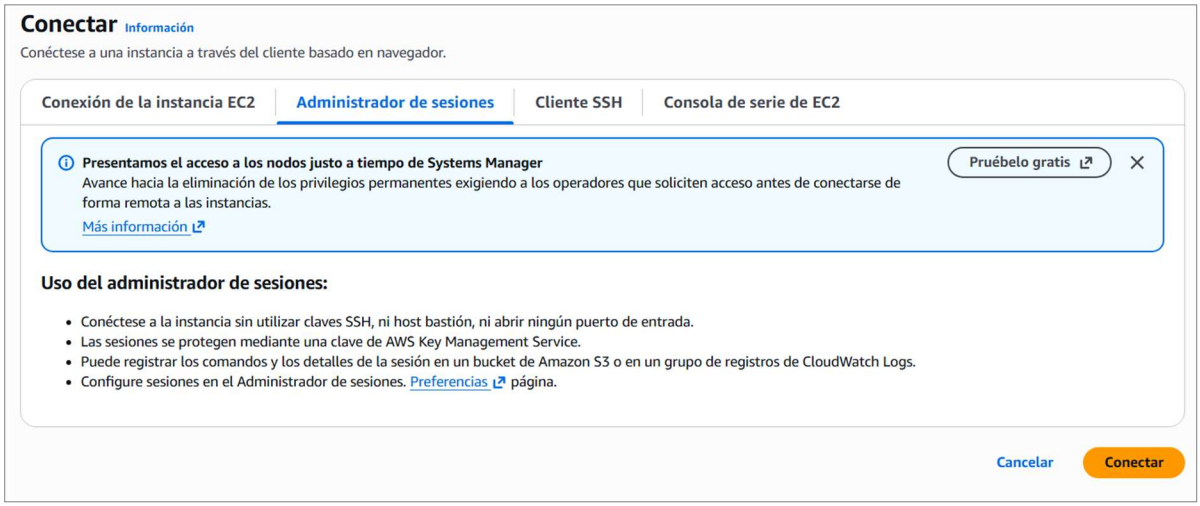
Validar la solución

Ahora verificaremos si el software malicioso es bloqueado.

Nos dirigimos al panel de instancias, seleccionamos la instancia *TestInstance* y hacemos clic en *Conectar*



En la pestaña *Administrador de sesiones* hacemos clic en *Conectar*



Con *wget* descargamos el contenido del sitio web

```
sh-4.2$ wget http://malware.wicar.org/data/js_crypto_miner.html
--2026-01-12 23:23:39--  http://malware.wicar.org/data/js_crypto_miner.html
Resolving malware.wicar.org (malware.wicar.org)... 208.94.116.246, 2607:ff18:80:6::6a08
Connecting to malware.wicar.org (malware.wicar.org)|208.94.116.246|:80... connected.
HTTP request sent, awaiting response...
```

```
sh-4.2$ wget http://malware.wicar.org/data/java_jre17_exec.html
--2026-01-12 23:24:13--  http://malware.wicar.org/data/java_jre17_exec.html
Resolving malware.wicar.org (malware.wicar.org)... 208.94.116.246, 2607:ff18:80:6::6a08
Connecting to malware.wicar.org (malware.wicar.org)|208.94.116.246|:80... connected.
HTTP request sent, awaiting response...
```

Los archivos han sido bloqueados por el firewall de red.

Ahora eliminamos los archivos maliciosos que descargamos anteriormente

```
sh-4.2$ rm java_jre17_exec.html js_crypto_miner.html
sh-4.2$ ls
sh-4.2$
```